

Analisis Kerentanan Aplikasi Web Menggunakan Framework OWASP dan Teknik SQL Injection & Cross-Site Scripting (XSS)

Linda Setia Ardani¹

¹Program Studi D3 Teknik Informatika, Politeknik Purbaya, Kabupaten Tegal, NIM 2402037,
lindaardani13@gmail.com

Abstrak

Pesatnya pertumbuhan aplikasi web diiringi oleh lonjakan ancaman keamanan siber, khususnya SQL Injection dan Cross-Site Scripting (XSS) yang masuk kategori kritis OWASP Top 10. Penelitian ini bertujuan menganalisis celah keamanan aplikasi web berbasis framework OWASP serta membedah teknik serangan tersebut melalui studi literatur riset terdahulu. Temuan menunjukkan bahwa kedua jenis serangan ini masih mendominasi dan sangat berbahaya. Riset ini berkontribusi memberikan rekomendasi penguatan sistem yang dapat diimplementasikan demi memproteksi aplikasi web dari ancaman siber.

Kata Kunci: OWASP, SQL Injection, Cross-Site Scripting, Keamanan Web, Penetration Testing

Informasi Artikel:

Dikirim	:	Januari – Juni 2026, Vol 1 (1) : hlm 1-10
Ditelaah	:	©2026 Politeknik Purbaya.
Diterima	:	All rights reserved.
Publikasi	:	

1. PENDAHULUAN

Perkembangan teknologi informasi dan komunikasi mengalami peningkatan signifikan selama beberapa dekade terakhir, mempengaruhi berbagai aspek kehidupan, termasuk cara kita bekerja dan mengakses informasi (Supriadi, Suryadi, Muslim, dan Samsumar, 2024). Website sering kali menjadi target serangan siber karena terdapat kerentanan yang bisa dimanfaatkan oleh penyerang. Di dunia pendidikan, sistem informasi akademik telah menjadi solusi penting dalam pengelolaan data mahasiswa dan administrasi. Namun, seiring dengan kemajuan teknologi, ancaman keamanan siber juga meningkat secara signifikan, menyebabkan risiko bagi individu maupun organisasi (Prapaskia dan Umam, 2026).

The Open Web Application Security Project (OWASP) secara rutin merilis daftar OWASP Top 10 yang memuat risiko keamanan paling kritis pada aplikasi web. Berdasarkan OWASP Top 10 2024, Injection (termasuk SQL Injection) dan Cross-Site Scripting (XSS) masih menduduki peringkat teratas sebagai kerentanan yang paling sering ditemukan dan paling berbahaya (OWASP Foundation, 2024). SQL Injection merupakan kerentanan yang memungkinkan penyerang menyisipkan kode SQL berbahaya ke dalam query database, yang dapat mengakibatkan akses tidak sah, manipulasi, atau penghapusan data sensitif (Fernanda, Data, dan Bakhtiar, 2025). Sementara itu, Cross-Site Scripting (XSS) memungkinkan penyerang menyuntikkan skrip berbahaya ke dalam halaman web yang akan dieksekusi oleh browser pengguna, yang dapat menyebabkan pencurian sesi, pengalihan ke situs berbahaya, atau pencurian data pengguna (Rapid7, 2025).

Berbagai penelitian telah dilakukan untuk mengidentifikasi dan mengatasi kerentanan keamanan web. Penelitian pada website HRD XYZ menggunakan metode penetration testing dengan framework OWASP ZAP berhasil mengidentifikasi berbagai kerentanan seperti SQL Injection, XSS, dan Broken Access Control (Haryono, 2025). Penelitian lain pada website GO!Design dengan metode OWASP dan OWASP ZAP menemukan 11 celah keamanan dengan tingkat keparahan bervariasi (Fathoni, et al., 2025). Sebuah studi evaluasi keamanan website RSUD RAA Soewondo Pati juga menemukan kerentanan seperti Path Traversal, SQL Injection, dan XSS dengan menggunakan OWASP ZAP (Prapaskia dan Umam, 2026). Penelitian pada website Universitas ARS menggunakan OWASP Top 10 2017 menemukan 13 kerentanan dengan tingkat keparahan rendah hingga sedang (Hidayatulloh dan Saptadiaji, 2021). Penelitian lain pada website fikom-methodist.com berhasil mengimplementasikan secure code untuk menangkal serangan CSRF menggunakan OWASP ZAP (Saragih, Tamalawe, dan Sarkis, 2023). Selain itu, penelitian pada sistem informasi akademik UMNU

Kebumen menemukan kerentanan konfigurasi seperti ketiadaan CSP, HSTS, dan header keamanan lainnya (Setiawan dan Fachri, 2022).

Penelitian ini bertujuan untuk menganalisis kerentanan keamanan pada aplikasi web menggunakan framework OWASP sebagai acuan standar serta mengkaji teknik SQL Injection dan Cross-Site Scripting (XSS) melalui studi literatur dari berbagai penelitian terdahulu. Hasil penelitian diharapkan dapat memberikan pemahaman mendalam tentang mekanisme serangan SQL Injection dan XSS serta rekomendasi perbaikan keamanan yang efektif untuk melindungi aplikasi web dari kedua jenis serangan tersebut.

2. METODE

Metode Rapid Application Development (RAD) merupakan pendekatan dalam pengembangan aplikasi yang dirancang untuk menghasilkan sistem dalam waktu yang relatif cepat dan efisien. Pendekatan ini menitikberatkan pada percepatan proses pengembangan guna memenuhi kebutuhan pengguna. Meskipun memiliki kemiripan dengan metode prototyping, RAD memiliki cakupan yang lebih menyeluruh. Metode ini terdiri dari empat tahapan utama, yang dalam penelitian ini disesuaikan dengan pendekatan studi literatur: Studi Literatur, Survey Literatur, Analisis Dokumen, dan Perancangan Kerangka Analisis.

2.1 Studi Literatur

Tahap ini dilakukan untuk mengkaji teori-teori dasar dan penelitian terdahulu yang relevan dengan topik keamanan aplikasi web, khususnya SQL Injection dan Cross-Site Scripting (XSS). Kajian mencakup konsep OWASP Top 10, teknik serangan SQL Injection dan XSS, serta metode penetrasian testing. Sumber referensi diperoleh dari jurnal ilmiah nasional dan internasional, prosiding konferensi, serta dokumen resmi dari OWASP. Literatur yang digunakan dipilih berdasarkan kriteria: (1) relevansi dengan topik SQL Injection dan XSS, (2) penerapan framework OWASP, (3) publikasi dalam 5 tahun terakhir, dan (4) terindeks di jurnal terakreditasi atau prosiding terpercaya.

2.2 Observasi dan Wawancara

Tahap ini merupakan adaptasi dari tahap Survey Lokasi pada metode RAD. Pada penelitian ini, Survey Literatur dilakukan dengan mengumpulkan dan memetakan jurnal-jurnal yang relevan dari berbagai database akademik seperti Google Scholar, Garuda (Garba Rujukan Digital), dan IEEE Xplore. Proses survey meliputi pencarian kata kunci seperti "OWASP", "SQL Injection", "Cross-Site Scripting", "penetration testing", dan "web application security". Hasil survey berupa kumpulan penelitian terdahulu yang kemudian dikelompokkan

berdasarkan objek penelitian, metode yang digunakan, dan temuan kerentanan yang diidentifikasi.

2.3 Analisis Dokumen

Tahap ini merupakan adaptasi dari tahap Wawancara pada metode RAD. Pada penelitian ini, Analisis Dokumen dilakukan dengan mengkaji dan mensintesis temuan dari berbagai penelitian yang telah dikumpulkan. Proses analisis meliputi: (1) identifikasi pola kerentanan yang umum ditemukan pada aplikasi web, (2) evaluasi efektivitas metode OWASP dalam mendeteksi kerentanan, (3) perbandingan hasil temuan antar penelitian, dan (4) identifikasi kesenjangan penelitian (research gap) yang masih perlu dieksplorasi lebih lanjut. Hasil analisis digunakan sebagai dasar untuk menyusun rekomendasi perbaikan keamanan.

2.4 Perancangan Kerangka Analisis

Tahap ini merupakan adaptasi dari tahap System Design pada metode RAD. Pada penelitian ini, Perancangan Kerangka Analisis dilakukan dengan menyusun struktur analisis yang sistematis untuk mengevaluasi kerentanan aplikasi web. Kerangka analisis mencakup: (1) klasifikasi kerentanan berdasarkan OWASP Top 10, (2) penilaian tingkat keparahan menggunakan CVSS (Common Vulnerability Scoring System), dan (3) penyusunan rekomendasi perbaikan berdasarkan best practice OWASP. Kerangka ini digunakan untuk menganalisis temuan dari berbagai penelitian terdahulu dan menghasilkan rekomendasi yang terstruktur dan dapat diimplementasikan oleh pengembang aplikasi web.

3. HASIL DAN PEMBAHASAN

3.1 Hasil Kajian Literatur

Berdasarkan kajian dari sepuluh penelitian terdahulu yang relevan dengan topik keamanan aplikasi web menggunakan framework OWASP, ditemukan berbagai temuan kerentanan yang bervariasi. Tabel 1 menyajikan rekapitulasi hasil kajian dari masing-masing penelitian.

Tabel 1. Rekapitulasi Hasil Kajian dari Penelitian Terdahulu

No	Penelitian	Objek	Temuan Utama	Risiko
1	Supriadi, et al. (2024)	Website Universitas	11 kerentanan (3 Medium, 4 Low)	Medium-Low
2	Prapaskia dan Umam (2026)	Website RSUD	SQL Injection, Path Traversal, XSS	High
3	Fathoni, et al. (2025)	GO!Design	11 celah (SQLi, XSS, Access Control)	High-Low
4	Haryono (2025)	Website HRD XYZ	SQL Injection, XSS	High

5	Fernanda, et al. (2025)	DVWA & Juice Shop	ZAP efektif untuk Error-based SQLi	-
6	Setiawan dan Fachri (2022)	SIAKAD UMNU	CSP Not Set, Missing Anti-Clickjacking	Medium
7	Hidayatulloh dan Saptadiaji (2021)	Universitas ARS	13 kerentanan (1 Medium, 12 Low)	Medium-Low
8	Saragih, et al. (2023)	fikom-methodist.com	14 CSRF (Low)	Low
9	Riandhanu (2022)	Website Absensi	20 kerentanan (1 Critical)	Critical-Low
10	Adrian, et al. (2025)	E-commerce	SQL Injection CVSS 9.1	Critical

Sumber: analisis literatur, 2026

3.2 Analisis SQL Injection

SQL Injection masih menjadi kerentanan paling banyak ditemukan. Penelitian Fernanda, Data, dan Bakhtiar (2025) menunjukkan OWASP ZAP efektif sebagai detektor awal namun lemah pada Blind SQL Injection. Adrian, Ibnuragaha, dan Nuha (2025) menunjukkan SQL Injection dengan CVSS 9.1 (Critical) memiliki dampak bisnis tinggi dan implikasi kepatuhan regulasi.

3.3 Analisis Cross-Site Scripting (XSS)

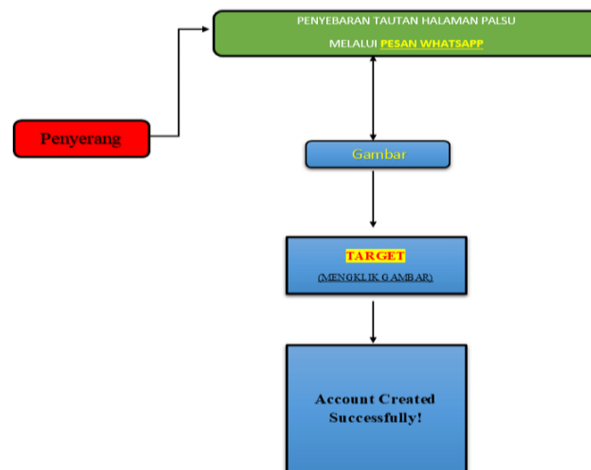
XSS juga sering ditemukan. Hidayatulloh dan Saptadiaji (2021) menemukan kerentanan konfigurasi seperti Cookie No HttpOnly Flag. Setiawan dan Fachri (2022) menemukan ketiadaan CSP sebagai celah potensial meskipun sanitasi input sudah kuat.

3.4 Analisis Kerentanan Konfigurasi

Supriadi, Suryadi, Muslim, dan Samsumar (2024) menemukan kerentanan konfigurasi: Absence of Anti-CSRF Tokens, CSP Header Not Set, Missing Anti-Clickjacking Header, Server Leaks Information, HSTS Not Set, dan X-Content-Type-Options Missing.

Saragih, Tamalawe, dan Sarkis (2023) pada website fikom-methodist.com berhasil mengidentifikasi 14 celah kerentanan CSRF (Absence of Anti-CSRF Token) menggunakan OWASP ZAP. Penelitian ini berhasil mengimplementasikan secure code dengan mengaktifkan CSRF protection pada framework CodeIgniter.

Gambar 1. Alur Serangan CSRF melalui Media Sosial



Sumber: Saragih, Tamalawe, dan Sarkis (2023)

Gambar 1 menunjukkan alur serangan CSRF yang dilakukan oleh penyerang. Penyerang membuat halaman palsu yang berisi form registrasi dengan parameter yang sudah diisi (name, email, role). Tautan halaman palsu disebarakan melalui WhatsApp kepada target. Ketika target mengklik gambar yang tampak sah, secara otomatis permintaan HTTP dikirim ke server dan akun admin baru berhasil dibuat tanpa sepengetahuan korban (Saragih, Tamalawe, dan Sarkis, 2023).

3.5 Pembahasan dan Rekomendasi

Berdasarkan kajian, pola kerentanan dominan adalah SQL Injection, XSS, dan Security Misconfiguration. OWASP ZAP efektif sebagai screening tool namun perlu dikombinasikan dengan alat lain seperti SQLMap untuk hasil yang lebih akurat (Fernanda, Data, dan Bakhtiar, 2025).

Tabel 2. Rekomendasi Perbaikan

Kerentanan	Rekomendasi
SQL Injection	Parameterized query, sanitasi input, least privilege
XSS	CSP, output encoding, HttpOnly flag
CSRF	Anti-CSRF token, aktivasi proteksi framework
Clickjacking	X-Frame-Options header
Security Misconfiguration	HSTS, hapus X-Powered-By, X-Content-Type-Options

Sumber: analisis literatur. 2026

4. KESIMPULAN

Penelitian ini menganalisis kerentanan keamanan aplikasi web menggunakan framework OWASP melalui studi literatur dari sepuluh penelitian terdahulu. Berdasarkan hasil kajian, SQL Injection dan Cross-Site Scripting (XSS) terbukti masih menjadi kerentanan yang paling kritis dan sering ditemukan pada aplikasi web, sebagaimana tercantum dalam OWASP Top 10. OWASP ZAP terbukti efektif sebagai alat pemindaian awal untuk mendeteksi SQL Injection dan XSS, namun memiliki keterbatasan dalam mendeteksi Blind SQL Injection yang memerlukan analisis manual dan alat tambahan seperti SQLMap (Fernanda, Data, dan Bakhtiar, 2025). Selain itu, kerentanan konfigurasi keamanan seperti ketiadaan Content Security Policy (CSP), HTTP Strict Transport Security (HSTS), dan X-Frame-Options juga sering ditemukan pada berbagai aplikasi web yang diuji (Supriadi, et al., 2024; Setiawan dan Fachri, 2022).

Implikasi dari penelitian ini adalah perlunya organisasi pengembang aplikasi web untuk mengimplementasikan praktik keamanan dalam siklus pengembangan perangkat lunak (Secure SDLC), melakukan pengujian keamanan secara rutin menggunakan framework OWASP, serta menerapkan rekomendasi perbaikan seperti parameterized query untuk mencegah SQL Injection, Content Security Policy (CSP) untuk mencegah XSS, dan Anti-CSRF token untuk mencegah serangan CSRF. Penelitian selanjutnya dapat mengembangkan deteksi kerentanan dengan machine learning, menguji efektivitas Web Application Firewall (WAF), atau memperluas objek penelitian pada aplikasi web dengan teknologi modern seperti React, Angular, atau Node.js.

DAFTAR PUSTAKA

- Armando, Y. (n.d.). *Penetration Testing Tangerang City Web Application With Implementing OWASP Top 10 Web Security Risks Framework*. Retrieved <https://tangerangkota.go.id/eninta-ibrena,+5.+Naikson>. (n.d.).
- Fahmi Aulia Hakim, A., Akbar, R., Alfarizi Ramadiyansa, M., Rizky Sinaga, M., Raya Palembang -Prabumulih Km, J., Ilir, O., & Selatan, S. (2025). ANALISIS KERENTANAN KEAMANAN WEBSITE SISTEM MANAJEMEN ABSENSI KARYAWAN GO DESIGN MENGGUNAKAN METODE OWASP. In *Jurnal Mahasiswa Teknik Informatika* (Vol. 9, Number 4).
- Fernanda, R., Data, M., & Bakhtiar, F. A. (2026). *ANALISIS EFEKTIVITAS OWASP ZAP DALAM MENDETEKSI KERENTANAN TERHADAP SERANGAN SQL INJECTION* (Vol. 10, Number 3). <http://j-ptiik.ub.ac.id>

- Hidayatulloh, S., & Saptadiaji, D. (n.d.). *Penetration Testing pada Website Universitas ARS Menggunakan Open Web Application Security Project (OWASP)*. Retrieved <http://jurnal.itg.ac.id/>
- Kholilul Adrian, M., Deshanta Ibnugraha, P., & Hudan Nuha, H. (2025). Integrating CVSS, OWASP, and APPI for a Comprehensive Risk Analysis of SQL Injection Vulnerabilities in E-Commerce. *Journal : Information Technology Journal*, 7(1).
- Riandhanu, I. O. (2022). Analisis Metode Open Web Application Security Project (OWASP) Menggunakan Penetration Testing pada Keamanan Website Absensi. *Jurnal Informasi Dan Teknologi*. <https://doi.org/10.37034/jidt.v4i3.236>
- Setiawan, E., & Fachri, F. (2025). *Pengujian dan Mitigasi Kerentanan Website Sistem Informasi Akademik Universitas Ma'arif Nahdlatul Ulama Kebumen dengan OWASP ZAP* (Vol. 8, Number 1).
- Supriadi, D., Suryadi, E., Muslim, R., Delsi Samsumar, L., & Teknologi Mataram, U. (n.d.). IMPLEMENTASI VULNERABILITY ASSESSMENT OWASP (OPEN WEB APPLICATION SECURITY PROJECT) PADA WEBSITE UNIVERSITAS TEKNOLOGI MATARAM. In *Journal of Data Analytics, Information, and Computer Science (JDAICS)* (Vol. 1).
- Yudanta Prapaskia, D., & Umam, C. (2026). Analisis Keamanan Website UPT RSUD RAA Soewondo Pati Berdasarkan Hasil Penetration Testing Menggunakan Owasp. *Jurnal Algoritma*, 23(1). <https://doi.org/10.33364/algoritma/v.23-1.3429>